

# The 2026 State of Product Security

FOR THE **✦ AI ERA**



PRESENTED BY  **cyclo**

# Table of Contents

|                                                                                         |    |
|-----------------------------------------------------------------------------------------|----|
| The Great Convergence: Secure Software by Default in the AI Era                         | 03 |
| Vibe Coding and the Rise of the 10X Developer                                           | 04 |
| Executive Summary                                                                       | 05 |
| Research Methodology                                                                    | 05 |
| Key Insights                                                                            | 06 |
| INSIGHT #1    AI-Generated Code is Security's Biggest Blind Spot                        | 07 |
| INSIGHT #2    Shadow AI and Tool Sprawl Expand the Attack Surface                       | 08 |
| INSIGHT #3    Product Security Is the Unsung Hero of the AI Era                         | 09 |
| INSIGHT #4    AI Visibility is Lagging Behind                                           | 10 |
| INSIGHT #5    Governance and Compliance Are the Missing Links in AI Security            | 11 |
| INSIGHT #6    Productivity and Time-to-Market Validate AI's Promise                     | 12 |
| INSIGHT #7    AI Adoption Creates a Push-and-Pull Between IT, Engineering, and Security | 13 |
| INSIGHT #8    Security Budgets are Higher Than Ever                                     | 14 |
| INSIGHT #9    AI Has Changed What Security Leaders Expect From Vendors                  | 15 |
| INSIGHT #10    More Tools, More Chaos. Convergence Is the Answer                        | 15 |

# The Great Convergence: Secure Software by Default in the AI Era

The AI revolution has forced teams to take a new approach to product security.

That's because AI innovation is outpacing adoption, and adoption is outpacing security. More code is being generated faster than ever thanks to AI co-pilots, and AI tools are being adopted and integrated into workflows without careful governance.

Security teams have tried to fight fire with fire by adding more security tools to their stacks, but fragmented tools aren't the solution.

For so long, we've treated Application Security Testing, supply chain security, and (more recently) ASPM as separate categories and specialized solutions. AST identifies vulnerabilities in code, supply chain security monitors dependencies, and ASPM provides visibility and prioritization. That approach made sense in the pre-GenAI world, when specialization helped solve discrete problems. But today specialization alone creates fragmentation and blind spots.

The magic happens when they're combined.

When AST, supply chain security, and ASPM converge, they provide unified visibility, context, and prioritization. And with shadow AI proliferating across organizations and AI-generated code introducing new attack vectors, this isn't optional. Security that extends across the entire product lifecycle (from the code developers generate, to the supply chains that support it, to the way applications are built, delivered, and maintained) is the only way to manage risk at the scale that today's software ecosystems demand.

But when we talk about "convergence", that doesn't mean simply cobbling together point solutions under one brand. That just recreates the same fragmented chaos I mentioned earlier.

Real convergence means purpose-built specialization inside a single platform. It means cutting through the noise, reducing false positives, and giving security teams the clarity they need to focus on what matters most. It means empowering developers and security teams alike to innovate at speed, without compromise.

The bottom line: product security is the natural evolution, and it's built for the AI era. It's not just defense, it's a business enabler that builds trust, speeds delivery, and allows organizations to innovate with confidence.

This has been Cyscale's mission from day one: to secure the software the world depends on. In this new era, that mission has never been more urgent. AI is rewriting the rules of software creation, and security must evolve in step. Not as a barrier, but as a catalyst for innovation.

The AI era won't wait. Neither can security. At Cyscale, we're here to bring order to the chaos, to help you regain control, and to enable you to protect your products—and the trust they represent—with confidence.

“Security that extends across the entire product lifecycle (from the code developers generate, to the supply chains that support it, to the way applications are built, delivered, and maintained) is the only way to manage risk at the scale that today's software ecosystems demand.”



**Lior Levy**  
CEO, Cyscale

# Vibe Coding and the Rise of the 10X Developer

If visibility is the “what,” governance and compliance are the “why” and “how”, defining who sets the rules, how those rules are enforced, and whether organizations are following them.

But more than half (52%) of organizations still lack any formal or centralized governance framework for managing AI adoption. Instead, they rely on decentralized or ad-hoc approvals, creating inconsistencies, duplication, and blind spots in oversight. Shadow AI (as discussed in Insight #2) only deepens this fragmentation as employees adopt unvetted tools outside official procurement channels.

## The Vibe Coding Phenomenon

When we say “vibe coding,” we’re talking about the intuitive, rapid generation of code with an AI code assistant. Developers (and even non-developers) can sketch an idea in plain language, let an AI model build the code, and move on. The benefits are obvious: speed, productivity, and a lower barrier to entry for new contributors.

But this acceleration carries risks and can turn into a nightmare for security teams. AI-generated code often (re)introduces insecure patterns, lacks context, and adds technical debt that can quietly pile up behind the scenes. This problem is compounded by the rise of “shadow AI”: unapproved, unmonitored tools that developers adopt without oversight. Beyond creating governance and compliance gaps, these tools introduce novel risks, from exposing sensitive data to generating code through opaque models that can’t be validated for security.

**The reality:** AI-assisted development certainly accelerates code creation. But it has also compounded the complexity and multiplied the opportunities for attackers to exploit weaknesses.

## The 10X Developer Dilemma

For experienced engineers, AI tools act as force multipliers, enabling them to produce 10 times more output. But less experienced developers may rely on AI to write the majority of their code, with some contributing only 10% themselves. These developers lack the experience to recognize insecure coding practices or to spot when AI output introduces business logic flaws.

Without that context, insecure code can slip through unchecked and create vulnerabilities that scale just as fast as the productivity gains.

This dual dynamic contributes to a hybrid problem with developers producing far more code, and much of that code containing more vulnerabilities. And with AI tooling costs skyrocketing, organizations face a double bind: they’re spending millions on development acceleration while potentially multiplying their security exposure.

## The Security Response Gap

Traditional tools weren’t built for this moment. Fragmented solutions only widen the gap between developer adoption and security’s ability to keep pace. The question now is whether capacity for risk creation will continue to outpace capacity for risk reduction. That tension is at the heart of this year’s report.

That’s why this year’s report draws directly from the perspectives of CISOs, AppSec and ProductSec leaders, and developers themselves. Through extensive research and conversations with security and development teams across industries, we set out to understand how organizations are navigating this transformation, and what separates those thriving in the AI era from those struggling to keep up.



# Exec Summary

Our latest research shows that 100% of organizations today have AI-generated code in their codebase, and 97% are actively using or piloting AI coding assistants. **AI adoption has already happened.**

But as AI transforms how software is built, it's also breaking how it's secured. Not only does this expand the attack surface, but it does so at a time when adversaries are also embracing AI to accelerate exploits of existing and new vulnerabilities and attack vectors.

The result: a runaway train that legacy application security tools and strategies can't contain or control. The conditions for the next major supply chain incident are not-so-quietly taking shape beneath the surface. We know it will be harder to detect, harder to contain, and every bit as consequential as SolarWinds.

That's why we set out to understand how AI is reshaping product security from the inside out. How teams are adopting it, where governance is breaking down, and what actions you should take to close the gap between innovation and control.

Not surprisingly, no one action will elevate your product security program for the AI era. Early signs point to coordinated efforts across familiar categories: people, process, and technology.

Developers require additional education and enablement on secure AI development. Security checks must be integrated into AI workflows to govern AI technologies and augment coding assistants with security expertise. And technology vendors must deliver control through consolidation and synergies that translate code-to-runtime contextual awareness into intelligent, and increasingly automated, actions.

## Research Methodology

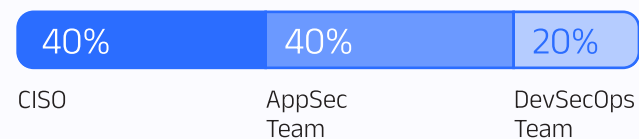
Cycode commissioned an independent, vendor-agnostic survey of 400 security leaders — including CISOs, AppSec Directors, and DevSecOps managers — across the UK and US. Notably, 50% of respondents work at organizations with over 5,000 employees.



Survey Conducted in  
**October 2025**



**400**  
Respondents



**North America**  
Market



# Key Takeaways

1

## **AI-Generated Code Is Security's Biggest Blind Spot:**

97% of organizations are already using or piloting AI coding assistants, and not a single respondent reported zero AI-generated code in their environment. Yet only 19% have full visibility into where AI is used, and 65% say their overall security risk has increased since adoption.

2

## **Shadow AI Expands the Attack Surface:**

Unapproved AI tools are proliferating across the SDLC, bypassing procurement and compliance. Over half of security leaders cite AI tool usage and software supply chain risk as one of their top three blind spots.

3

## **Governance and Security Oversight Are Falling Behind:**

More than half (52%) still lack centralized governance for AI adoption. Decentralized or ad-hoc approvals create inconsistencies, duplication, and blind spots, echoing the same weaknesses that once enabled large-scale supply chain breaches.

4

## **Product Security Is Emerging as the Linchpin:**

99% of organizations now have product security coverage, with most running dedicated teams. Their mandate extends across AppSec, cloud, APIs, and AI to bridge innovation speed with security control.

5

## **Convergence Is the Path Forward:**

After years of tool sprawl, 97% of organizations plan to consolidate their AppSec stack within 12 months. Real convergence means unified visibility, context, and control so security teams can cut through noise and fix what matters most.



## **What Does it All Mean?**

AI has permanently changed how software is written, and with it, how security must operate. 2026 will be the year organizations decide whether AI becomes their greatest accelerator or their greatest liability. The ones that thrive will be those that bring security, development, and governance back together under one unified, converged platform.

# AI-Generated Code is Security's Biggest Blind Spot

AI coding assistants aren't novel anymore. 97% of organizations are already actively using or piloting them, and 100% of respondents report they have AI-generate code in their codebase.

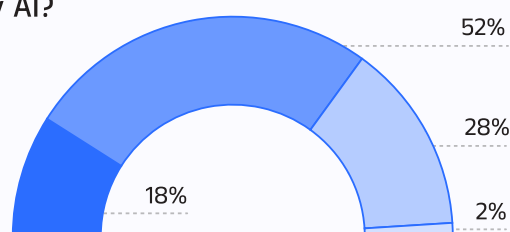
The rate of adoption and maturity of governance isn't uniform, though, with AI adoption at mid-sized companies outpacing the largest enterprises.

Either way, AI's influence on codebases is undeniable. But just how pervasive is it? Nearly one-third (30%) say AI generates most of their code, with 2% reporting that more than 75% of their code now comes from AI.

It's clear that development teams are embracing AI rapidly and will continue to do so. That's inevitable. The challenge is managing and governing a reality where AI is (or will be) the primary generator of new code. This is especially difficult because, unlike human developers, AI agents aren't vetted employees. They're opaque systems that introduce new risks and require an extra layer of oversight.

## Approximately what percentage of your codebase is now generated by AI?

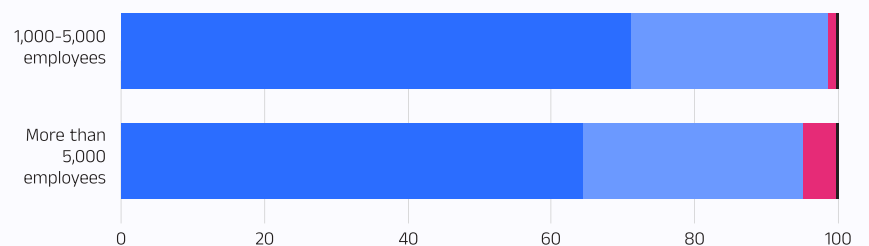
- 1%-25%
- 26%-50%
- 51%-75%
- 76%-100%



71% of companies with 1-5k employees are actively using AI coding assistants compared to 64% at the largest enterprises. This gap may reflect both needs (smaller teams leaning on AI to scale their capacity) and speed, as mid-sized orgs often adopt new tools more quickly than large, process-heavy enterprises.

## Has your organization adopted AI coding assistants (e.g. Copilot, Cursor, Claude, ChatGPT) in development workflows?

- Yes, already using
- Yes, piloting now
- No, but plan to in the next 12 months
- We have no official adoption, however I am aware of people using these



Security teams want to apply the same scrutiny to AI-generated code as human-written code, but most don't know where to start.

That gap explains why AI-generated code is viewed as the #1 blind spot in modern security posture (see insight #2 for the other top blind spots) according to survey respondents. It's no wonder securing it has become the **top priority** for product security teams over the next year.

And code is just one piece of the puzzle...

"We know AI-coding tools are widely adopted, but how they are and will be governed is still something the security industry is learning, as well as how to usher in secure adoption of AI coding and enable the business while being cognizant of inherent risks in parallel."



**Chris Hughes**  
Resilient Cyber

# Shadow AI and Tool Sprawl Expand the Attack Surface

As teams adopt AI-powered tools, agents, and workflows across the SDLC, risks tied to adoption, governance, and integration are becoming as complex and consequential as the code itself.

Shadow AI sits at the center of this challenge. Employees are increasingly using unapproved or unmanaged AI tools and Model Context Protocols (MCPs) outside formal oversight, creating hidden dependencies and new points of exposure. These tools often handle proprietary or sensitive data but bypass the security reviews, procurement processes, and compliance checks that typically protect organizations. The result is a new class of untracked dependencies and unverified code contributions that quietly expand the attack surface.

This isn't just a visibility problem, it's a **supply chain security issue**.

Every AI model, plugin, or integration effectively becomes a new supplier, introducing components and logic with unknown provenance into production systems. When teams can't trace how or where AI-generated code was created, it undermines the integrity, traceability, and trust that modern supply chain security depends on.

It's no wonder security leaders are increasingly worried about the tools and ecosystems surrounding AI-generated code. More than half cited AI tool usage (54%) and software supply chain risks (51%) as key blind spots.

These trends reveal a larger truth: securing code isn't enough; organizations must also strengthen the systems, tools, and culture that govern how AI is used to create it.

## What do you consider to be the biggest blind spots in your current security posture in the AI era?

- #1 AI-generated code vulnerabilities
- #2 AI tools usage
- #3 Software supply chain risks
- #4 Secrets in code or productivity tools
- #5 Cloud misconfigurations
- #6 APIs

"As enterprises accelerate their use of AI in software development, the surface area for application security risk is expanding faster than traditional controls can manage. The rise of shadow AI compounds this challenge, creating new layers of exposure that often can't be fully seen or governed."



**Katie Norton**

Research Manager At IDC

# Product Security Is the Unsung Hero of the AI Era

Product security may not have always been the headline act in security conversations, but its role has steadily expanded. According to today's security and business leaders, it's now central to how organizations approach security in the AI era. In fact, nearly every organization we surveyed (99%) has some form of product security coverage, with most (4 out of 5) running dedicated teams rather than just individual roles.

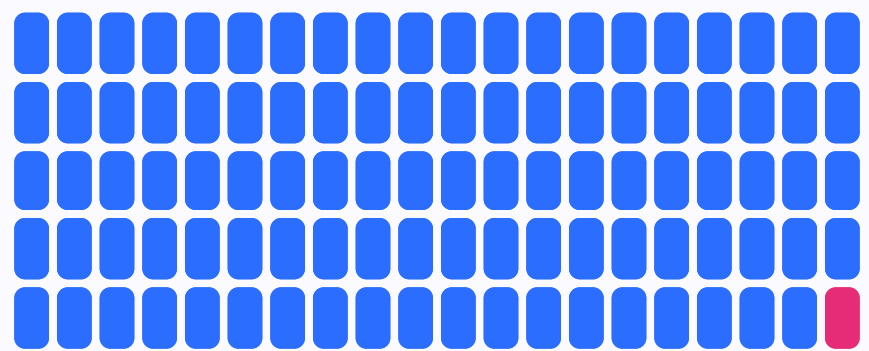
Its evolution into a central discipline was only a matter of time.

The attack surface has widened far beyond application code, now spanning cloud infrastructure, third-party dependencies, APIs, and increasingly, AI-generated code. Companies must also secure the fast-growing ecosystem of AI tools, shadow AI applications, MCPs, and, eventually, AI agents themselves. MCPs, which manage and serve relevant information and context to AI models, can dramatically improve the quality and relevance of AI outputs; however, they also represent a new potential point of exposure that security teams must manage.

Regulatory pressure is rising, demanding security across the entire product lifecycle. A focus that is rapidly expanding from SBOMs to include the essential governance of AI models through AI Bill of Materials (AIBOMs).

Still, product security remains fragmented. Reporting lines vary widely, most often to the CISO (36%), but also to engineering leaders (24%), CTOs (23%), and CIOs (17%). Of course, where product security sits has real implications: a CISO-owned team may lean security-first, while reporting into engineering skews toward productivity and speed.

**99%** of surveyed organizations have a product security function.



Fragmentation isn't just organizational, though. Security responsibilities are scattered across siloed teams using disparate tools and metrics, often leaving gaps and blind spots. Add in the variety of assets (from code to hardware to cloud infrastructure) and achieving a unified view of product risk becomes a challenge.

Their responsibilities reflect this expansive yet fragmented scope.

The top mandate is application security (66%), a clear sign that product security and AppSec are increasingly merging into one. From there, the scope extends into supply chain risk, cloud infrastructure, APIs, and compliance, areas once split across multiple teams but now converging under one. How they measure success reinforces this dual role: reducing vulnerabilities in production (67%), strong developer adoption (67%), and faster time-to-fix (65%).

## Top 5 Product Security KPIs

- |    |                                     |
|----|-------------------------------------|
| #1 | Fewer Vulnerabilities in Production |
| #2 | Developer Adoption                  |
| #3 | Faster Time-to-Fix                  |
| #4 | Compliance Readiness                |
| #5 | Reduced Tool Sprawl                 |

## Top 6 Responsibilities

- |    |                    |
|----|--------------------|
| #1 | AppSec             |
| #2 | CloudSec           |
| #3 | Supply Chain       |
| #4 | API                |
| #5 | Regulatory/AI      |
| #6 | Vulnerability Mgmt |



# AI Visibility is Lagging Behind

Complete visibility across vulnerabilities, attack surfaces, and now AI is the dream of every security leader, even if most know it's a moving target.

But today, adoption is racing ahead faster than visibility can keep up.

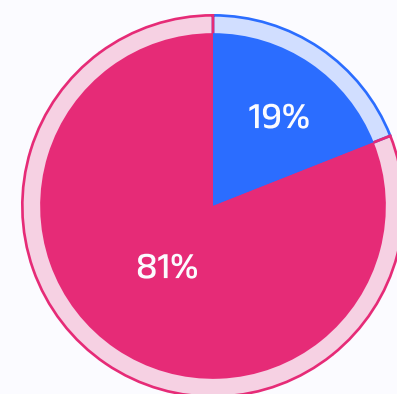
Nearly universal adoption of AI coding assistants stands in stark contrast to the fact that **only 19% report complete visibility of where and how AI is being used**. The consequences are already tangible, with measurable impacts on risk and resilience.

Almost **two-thirds (65%)** of respondents report an overall increase in security risk (i.e. vulnerability count) since adopting AI. And when insecure or unmonitored AI-generated code enters production, it exposes organizations to a double threat: heightened breach risk and the downstream fallout of lost trust, regulatory pressure, and operational disruption.

In short, AI's benefits are outpacing AI governance (at least for now). Companies will need to re-think and tighten processes because while lack of visibility starts as a technical problem, its impacts are deeply strategic, affecting everything from trust and compliance to revenue and customer retention.

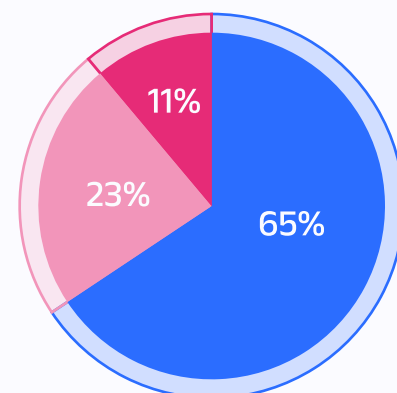
Do you have complete visibility of how AI is used across development?

No  
Yes



How has the use of AI coding assistants impacted your organization's vulnerability count?

Increase  
No change  
Decrease



Shadow AI is A Major Concern



Only 19% Report Full Visibility into AI

# Governance and Compliance Are the Missing Links in AI Security

If visibility is the “what,” governance and compliance are the “why” and “how”, defining who sets the rules, how those rules are enforced, and whether organizations are following them.

But more than half (52%) of organizations still lack any formal or centralized governance framework for managing AI adoption. Instead, they rely on decentralized or ad-hoc approvals, creating inconsistencies, duplication, and blind spots in oversight. Shadow AI (as discussed in Insight #2) only deepens this fragmentation as employees adopt unvetted tools outside official procurement channels.

**48%** Formal, Centralized Governance

**26%** Existing Process Integrations

**8%** Decentralized Approval

**6%** No Formal Policy (Permissive Use)

**5%** Official Prohibition (With Shadow Use)

**4%** Official Prohibition (Enforced)

**3%** No Current Use

Importantly, governance and compliance are closely related but distinct. Governance establishes direction: the strategic intent and policies that guide how AI should be used responsibly. Compliance ensures execution: the mechanisms, controls, and documentation proving that teams are following those rules. Training often sits at the intersection of both, translating policy into practice.

But as AI evolves, training alone can't keep up. What's secure today may not be tomorrow. Effective AI protection depends on aligning people, processes, and technology, while training elevates awareness, governance defines guardrails, and tools enforce visibility and accountability.

That's why forward-looking organizations are expanding traditional frameworks like SBOMs to include AI Bills of Materials (AIBOMs), which document every model component, dataset, and dependency to improve transparency and auditability.

Already, 56% of organizations say product security teams own regulatory and compliance responsibilities, a sign that governance is becoming a defining part of their remit. For these teams, this shift isn't just about compliance; it's a chance to lead how AI security is governed, setting the standards that will define trust, transparency, and accountability in the years ahead.

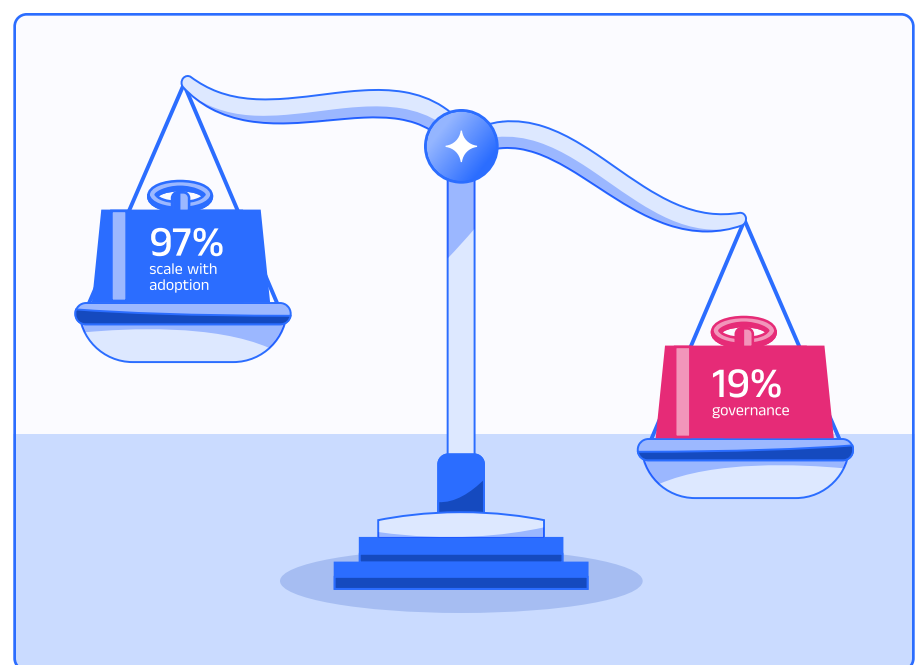
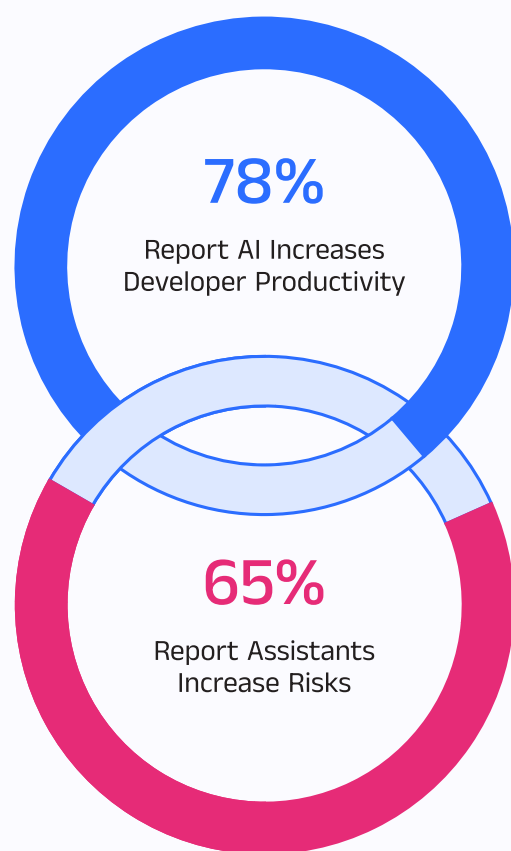


# Productivity and Time-to-Market Validate AI's Promise

No one adopted AI coding assistants expecting them to slow development down. The business case was always about speed and efficiency, and the data shows the payoff is real.

Nearly eight in ten organizations report higher developer productivity (77%) and 72% point to faster time-to-market. These benefits ripple well beyond the dev team, shaping product roadmaps, customer experience, and overall competitiveness.

## AI Risks and Rewards go Hand-in-Hand



And, while these tools often do make developers' daily work easier, adoption isn't just bottom-up. Leadership is also pushing to capture ROI from AI investments, especially as companies look to do more with leaner teams.

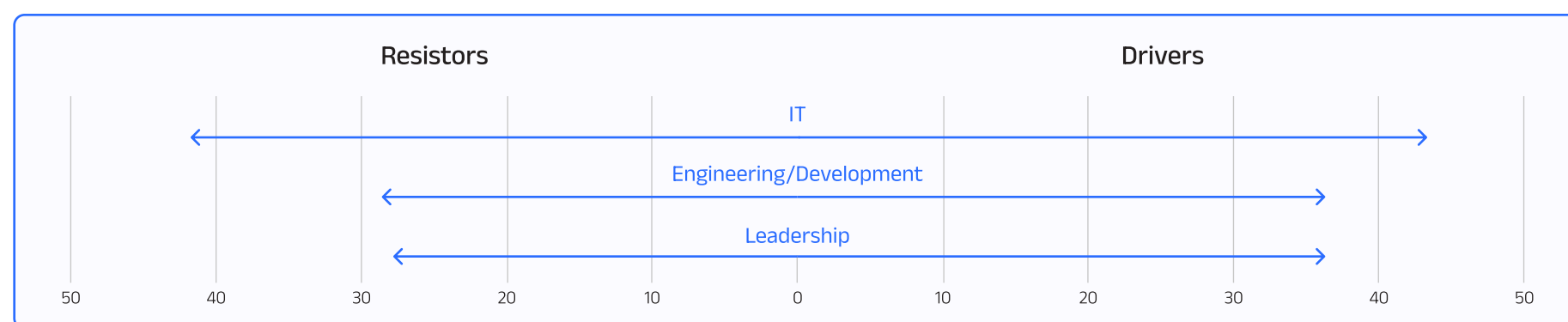
Like everything, AI adoption forces compromises and trade-offs. Currently, the imbalance is heavily weighted toward adoption (97%) over governance (only 19% report full visibility into AI) and risk management (65% acknowledge AI increases risk).

Teams know the risks are real, yet the pressure to innovate faster outweighs the fear of potential exposure. It's a calculated trade-off between competitive advantage and control, and for now, speed is winning.

The bottom line: AI is delivering undeniable productivity and efficiency gains, but it's doing so in an environment where security practices, governance, and regulation have yet to catch up. The challenge isn't whether AI delivers value (that much is clear) it's whether organizations can keep that value sustainable as the risks scale alongside it.

# AI Adoption Creates a Push-and-Pull Between IT, Engineering, and Security

The strongest push for AI adoption comes from IT/Operations, engineering, and leadership, who see clear gains in productivity, time-to-market, and ROI. Adoption reflects a convergence of pressures: leadership chasing strategic value and leaner operations, and developers embracing tools that ease the day-to-day grind.

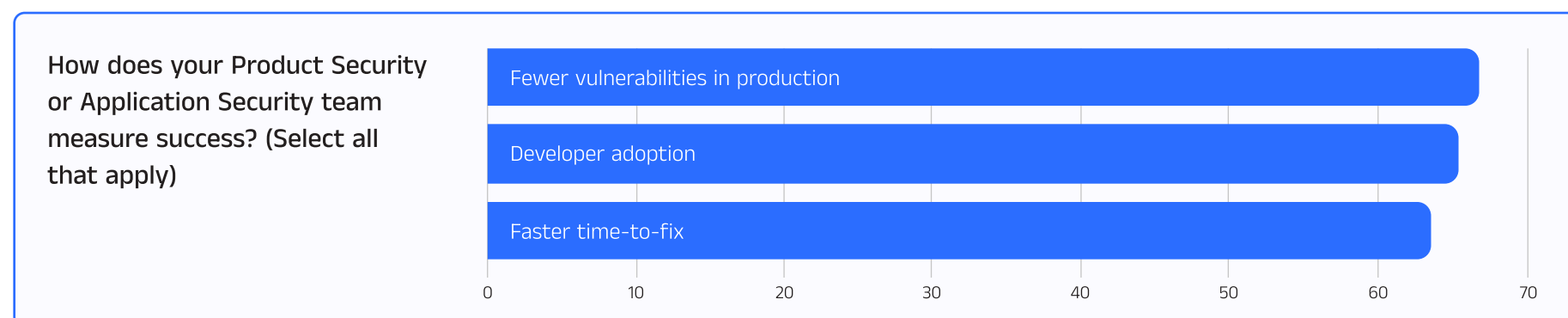


Interestingly, though, the same groups driving adoption are also resisting it. IT and operations hold the top spot for both categories, while an almost identical percentage of people view security as both a driver and a resistor of AI adoption. These teams do indeed wear two hats.

Security teams want to enable innovation, not block it. But as adoption accelerates without alignment or governance, they're forced into a reactive role, chasing shadow AI, playing catch-up on oversight, and working to secure code they didn't drive into production in the first place.

This tug-of-war reflects a deeper truth: the risk of missing a market opportunity often outweighs the risk of a potential (but uncertain) security incident. As a result, speed usually wins. That's exactly why product security matters: it's one of the few functions expected to enable speed and ensure safety.

Their success is measured by reducing vulnerabilities in production (67%), faster time-to-fix (65%), and strong developer adoption of secure practices (67%).



As we've explored, AI adoption complicates this balance. It fuels developer adoption and speed (metrics the business loves) while simultaneously introducing new vulnerabilities and risks that security must mitigate.

# Security Budgets are Higher Than Ever

Security priorities are shifting fast in response to AI's influence on software. The top mandates for the next 12 months are securing AI-generated code (50%), improving developer productivity without sacrificing security (45%), and defending against adversarial AI-powered attacks (44%).

## What are your top 3 priorities for the next 12 months?



This shift is showing up in budgets, with 39% of organizations expecting to increase AI-related AppSec spending by 50% or more in the next year. None expect a decrease, signaling what many leaders already know: traditional AppSec tools weren't built to handle the scale and complexity of AI.

## Approximately what percentage of your codebase is now generated by AI?

0% - None

0%

1% - 25%

13%

26% - 50%

47%

51% - 75%

34%

76% - 100%

5%

So, what will product security teams channel those budgets towards? Capabilities that directly move the needle on the metrics they're accountable for: reducing vulnerabilities in production, accelerating time-to-fix, and improving developer adoption of secure practices.



## INSIGHT #9

# AI Has Changed What Security Leaders Expect From Vendors

Rising budgets don't mean teams want more tools. They want smarter ones. In particular, they're looking for vendors that help them manage risk at scale by going beyond alerts and into action:

These expectations point to a fundamental mindset shift. Security teams aren't just securing AI; they're beginning to operate with it. It's less about fighting fire with fire and more about matching AI's speed, scale, and intelligence with the same force on the side of security.

But AI is just one piece. Teams are already buried under fragmented AppSec tools, from AST to supply chain security, each surfacing alerts without unified context. That explains why security leaders don't want more tools. They want platforms.

66%

want AI-driven prioritization of vulnerabilities

66%

want automated detection of vulnerabilities in AI-generated code

60%

want secure-by-default AI code generation guidance

57%

want AI-assisted remediation suggestions and fixes

## INSIGHT #10

# More Tools, More Chaos. Convergence Is the Answer

Nearly half of product security teams (44%) report that reducing tool sprawl is one of their performance metrics. That is telling. Consolidation and unifying fragmented tools has become a key performance indicator.

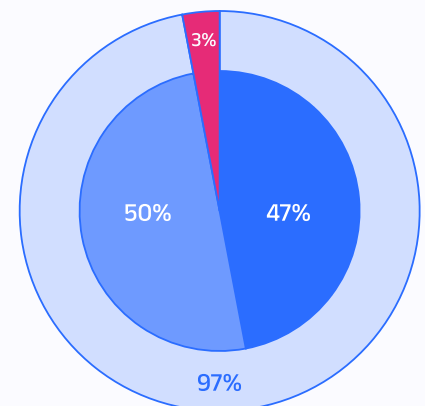
It's no surprise, then, that nearly every organization we surveyed (97%) says they have plans to consolidate their application security tools in the next 12 months.

Governance gaps, and shadow AI aren't isolated issues. They feed off each other. Weak governance makes shadow AI more likely, and shadow AI makes governance more difficult. Convergence breaks this cycle by consolidating visibility, context, and control in one platform.

Importantly, though, convergence doesn't mean cobbling together point solutions under one brand.

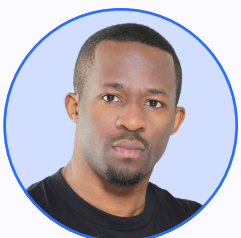
Do you plan to consolidate your application security tools in the next 12 months?

- Yes
- Partial Consolidation
- Full Consolidation
- No



That approach just recreates the same problems in a new wrapper. Real convergence means a purpose-built platform where AST + SSCS + ASPM work in concert to enrich security data with complete code-to-cloud context, power risk-based prioritization, and enable AI native capabilities like exploitability analysis and auto-remediation.

"As AI-generated code grows to become the norm for developers, organizations will have to move from fragmented controls to converged platforms built to allow them to balance security and speed for their product teams. The winners in this next chapter will be the teams that treat convergence not as a buzzword but as the architecture of resilience."



**Francis Odum**

Founder & CEO, Software Analyst

# The 2026 State of Product Security

FOR THE  AI ERA



PRESENTED BY  **cyclo**®

REQUEST A DEMO